

Enterprise Security Assessment Report – E-Commerce Infrastructure Security

Comprehensive Security Architecture Review, Business Impact Analysis, Preventive Security Controls, and Incident Response Strategy

Corso: Cybersecurity Analyst
Modulo: W20D4 (Pratica)
Piattaforma: Epicode
Studente: Nouman Javed Nizami
Data: 08/05/2026

Executive Summary

This report evaluates the security posture of an e-commerce infrastructure exposed to the Internet through a DMZ architecture. The assessment identifies risks associated with SQL Injection, Cross-Site Scripting (XSS), malware propagation, DDoS attacks, and lateral movement toward the internal network.

The report proposes preventive controls, business continuity protections, Incident Response procedures, and enterprise-level infrastructure hardening strategies aligned with modern cybersecurity best practices.

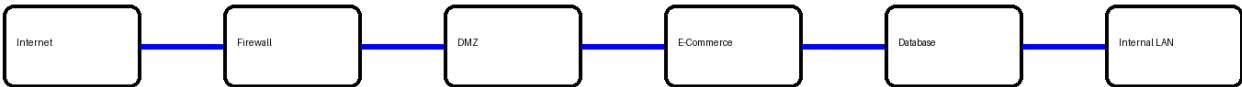
1. Original Infrastructure Analysis

The original infrastructure exposes an e-commerce application to the Internet through a firewall and a DMZ. The DMZ maintains communication paths toward the internal network, introducing a significant security risk.

If the web application server inside the DMZ becomes compromised, attackers may attempt:

- lateral movement;
- privilege escalation;
- malware propagation;
- pivoting toward internal systems;
- database compromise.

Original Infrastructure



Risk Assessment

Threat	Impact	Severity
SQL Injection	Database compromise	High
XSS	Session hijacking	Medium
DDoS	Service downtime	High

Malware Propagation	Internal network infection	Critical
Lateral Movement	Internal compromise	Critical

2. Preventive Security Controls

The infrastructure requires multiple defensive layers to mitigate modern web application attacks.

SQL Injection Mitigations

- Prepared statements and parameterized queries
- Input validation and sanitization
- Least privilege database accounts
- Web Application Firewall (WAF)
- Database segmentation
- Security patch management

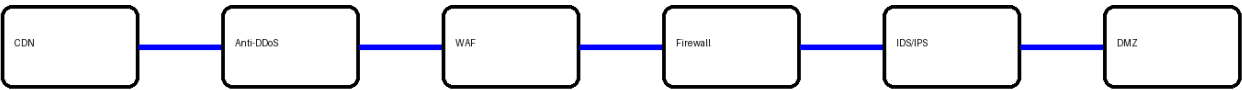
Cross-Site Scripting (XSS) Mitigations

- Output encoding
- Input sanitization
- Content Security Policy (CSP)
- HttpOnly and Secure cookies
- Server-side filtering
- WAF anti-XSS rules

Additional Preventive Measures

- IDS/IPS monitoring
- SIEM integration
- Centralized logging
- EDR deployment
- Secure VLAN segmentation

Preventive Security Controls



Threat → Impact → Mitigation Matrix

Threat	Impact	Mitigation
SQL Injection	Database compromise	Prepared statements + WAF
XSS	Session theft	CSP + Output Encoding
DDoS	Service outage	CDN + Anti-DDoS

Malware	Internal infection	Segmentation + EDR
Lateral Movement	Network compromise	Zero Trust + VLANs

3. Business Impact Analysis – DDoS Attack

The e-commerce platform becomes unavailable for 10 minutes due to a DDoS attack.

Average customer spending per minute: 1,500 €.

Business Impact Formula:

$1,500 \text{ €} \times 10 \text{ minutes} = 15,000 \text{ €}$ direct financial loss

Additional indirect business impacts include:

- reputational damage;
- customer trust reduction;
- SLA violations;
- future revenue loss;
- operational disruption.

4. Incident Response – Malware Infection

If the web application inside the DMZ becomes infected by malware, the main priority is preventing malware propagation toward the internal network.

Containment actions:

- isolate the compromised DMZ server;
- block DMZ to Internal Network communication;
- disable unnecessary firewall rules;
- quarantine suspicious traffic.

Detection activities:

- analyze firewall and server logs;
- verify Indicators of Compromise (IOC);
- inspect suspicious processes and connections;
- use EDR and antivirus solutions.

Recovery activities:

- restore clean backups;
- patch systems;
- rotate credentials;
- harden the infrastructure.

5. Incident Response Lifecycle

Preparation

Deploy SIEM, EDR, backups, segmentation, and monitoring systems.

Detection

Analyze logs, IOC indicators, suspicious traffic, and abnormal processes.

Containment

Isolate infected DMZ server and block communication with internal systems.

Eradication

Remove malware, patch vulnerabilities, and rotate credentials.

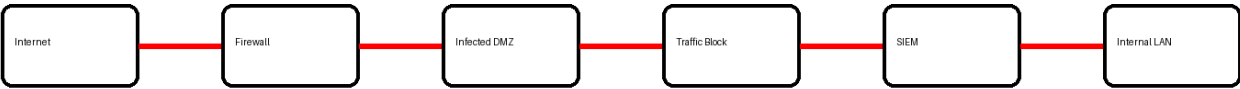
Recovery

Restore clean backups and monitor systems after reintegration.

Lessons Learned

Document the incident and improve future defensive controls.

Incident Response Containment



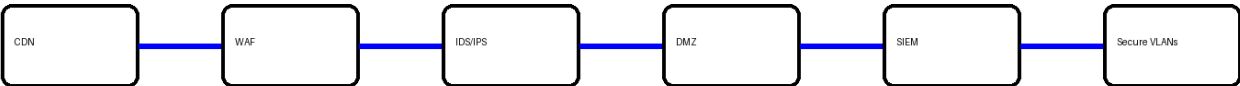
6. Complete Integrated Enterprise Solution

The final solution combines preventive controls, DDoS mitigation, segmentation, and Incident Response procedures into a unified enterprise security architecture.

Integrated technologies include:

- CDN and Anti-DDoS systems
- Web Application Firewall (WAF)
- IDS/IPS monitoring
- SIEM correlation and alerting
- EDR endpoint protection
- Reverse proxy architecture
- Database isolation
- Secure VLAN segmentation
- Centralized logging
- Backup and recovery infrastructure

Integrated Enterprise Security Architecture

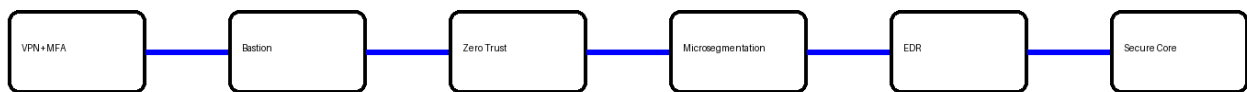


7. Aggressive Infrastructure Hardening

This section proposes an enterprise-grade hardening strategy based on Zero Trust principles.

- Zero Trust Architecture
- Microsegmentation
- Bastion Host administration
- VPN access with Multi-Factor Authentication (MFA)
- Role-Based Access Control (RBAC)
- Honeypot deployment inside the DMZ
- Immutable offline backups
- Disaster Recovery planning
- Continuous EDR monitoring
- Advanced SIEM analytics

Aggressive Hardening Architecture



Conclusion

The proposed architecture significantly improves infrastructure resilience, reduces attack surface, and aligns the environment with enterprise cybersecurity best practices.

By integrating preventive controls, DDoS protection, Incident Response procedures, Zero Trust principles, and advanced monitoring systems, the organization can drastically reduce the risk of compromise, malware propagation, and service downtime.